ISSUE 日本語解説資料

Issue #60 GCP preview security hardening implementation を整理する

GitHub で closed になっている issue 記録を、そのまま参照用 PDF に変換したもの。

Issue #60　更新: 2026/03/12

ソース: docs/portal/issues/issue-60-gcp-preview-security-hardening-implementation.md

GitHub: https://github.com/PLAYER1-r7/MultiCloudProject/issues/60

portal　セキュリティ　インフラ　GCP

この ISSUE の要点

Issue 54 で GCP preview security baseline は fixed したが、Cloud Armor tuning、credential scope review、GitHub environment / secret governance、audit trail の運用定着など、minimum baseline を live hardening に引き上げる実装作業は未着手である。このままだと、preview path は validation 済みでも、長期運用に必要な hardening depth が不足したままになる。

目標

GCP preview security hardening implementation を整理し、hardening scope、owner、evidence、non-goals を reviewable な実行 issue として固定する。

完了状態

ISSUE CLOSED

1. この Issue が扱っていたこと

まず Summary と Goal から、この Issue が何を決めるためのものだったかを短く押さえる。

Issue 54 で GCP preview security baseline は fixed したが、Cloud Armor tuning、credential scope review、GitHub environment / secret governance、audit trail の運用定着など、minimum baseline を live hardening に引き上げる実装作業は未着手である。このままだと、preview path は validation 済みでも、長期運用に必要な hardening depth が不足したままになる。

目標

GCP preview security hardening implementation を整理し、hardening scope、owner、evidence、non-goals を reviewable な実行 issue として固定する。

2. 完了判断の見方

Tasks、Definition of Done、Current Status の記述から、どこまで完了済みとして扱っているかを先に読む。

TASKS

4/4 項目が完了済みとして記録されている。

DEFINITION OF DONE

3/3 項目が完了済みとして記録されている。

ISSUE CLOSED / GitHub Issue: #60 / GitHub URL: https://github.com/PLAYER1-r7/MultiCloudProject/issues/60 / Sync Status: closed after re-review PASS / Close Status: closed — re-review confirmed Permissions-Policy / X-Permitted-Cross-Domain-Policies headers, Cloud Armor attachment, credential governance scoping, and repo hygiene (tfplan artifact removed, .gitignore updated) complete; no blockers / local issue record として security hardening implementation を固定した / `infra/modules/portal-gcp-static-delivery/main.tf` に retained preview 向け response header hardening を追加した / `infra/environments/gcp-preview/README.md` と `.github/workflows/README.md` に credential governance と audit evidence path を追記した / `/tmp/opentofu-1.11.0/tofu apply` により gcp-preview backend bucket の response headers を live 更新し、`Permissions-Policy` と `X-Permitted-Cross-Domain-Policies` を追加した / follow-up repo hygiene として generated tfplan artifact は削除し、tfplan pattern を ignore 対象へ追加した

3. 依存関係と読み進め方

Dependencies や前提 Issue がある場合は、ここで関連先を先に把握しておくと読みやすい。

依存関係

- Issue 52
- Issue 53
- Issue 54
- Issue 57

読み方の注意

この解説書は原文の意思決定や完了状態を読みやすくするための補助資料である。最終的な正本は原文 Issue にあり、判断変更時は原文側を先に更新する。

4. 用語集

原文に残る英語や実務用語のうち、訳し切らずに補助説明を付けた方が読みやすい語をここにまとめる。

原語	日本語の扱い	補足
fail-closed	安全側で失敗させる	判定できない場合に成功扱いせず、明示的に停止または失敗として扱う設計方針。
baseline	基準線	後続作業が参照する最小限の判断・実装・検証の出発点。
hardening	堅牢化	既存機能を壊れにくくし、運用や検証の安全性を高める作業。
production	本番環境	実際の利用者に公開される運用環境。
workflow	ワークフロー	GitHub Actions などで定義された自動処理の流れ。
owner	責任者	意思決定または更新責任を持つ担当者。文脈により product owner などを含む。
review	レビュー	内容や実装が要件を満たすか確認する工程。
evidence	証跡	判断や完了状態の根拠になるログ、表、文書、出力結果。
draft	下書き	まだ確定前だが議論やレビューの基礎として置かれた文書。
current status	現在の状態	Issue 文書時点での完了度合いや同期状況を示す節。

原語	日本語の扱い	補足
definition of done	完了条件	その Issue を完了とみなすために満たすべき条件。
task contract	タスク契約	対象、目的、スコープ、検証計画、リスクを明文化した作業契約。

5. 原文

以下に Issue 原文をそのまま掲載する。詳細な根拠、証跡、チェックリストはこの原文を参照する。

概要

Issue 54 で GCP preview security baseline は fixed したが、Cloud Armor tuning、credential scope review、GitHub environment / secret governance、audit trail の運用定着など、minimum baseline を live hardening に引き上げる実装作業は未着手である。このままだと、preview path は validation 済みでも、長期運用に必要な hardening depth が不足したままになる。

目標

GCP preview security hardening implementation を整理し、hardening scope、owner、evidence、non-goals を reviewable な実行 issue として固定する。

タスク契約

タスク契約

メタデータ
- タスク ID: ISSUE-60
- タイトル: GCP preview security hardening implementation を整理する
- 依頼者: repository owner
- 担当者: AI agent
- 対象アプリ: portal-web
- 対象環境: GCP preview security hardening
- 優先度: 中
- 先行条件: Issue 52 closed, Issue 53 closed, Issue 54 closed, Issue 57 proposed

目的
- 解決する問題: security baseline は fixed したが、Cloud Armor の tuning、credential / secret governance、audit evidence 運用を hardening step としてどこまで実施するかが未固定のため、preview path を長期運用へ接続しづらい
- 期待する価値: minimum baseline と hardening step の境界を保ったまま、preview path の security hardening scope、owner、evidence を固定できる

スコープ
- 含むもの: Cloud Armor hardening scope、credential / secret review、GitHub environment governance、audit evidence hardening、verification plan、open questions table の作成
- 含まないもの: full IAM redesign、SCC / SIEM 全面導入、application auth 導入、production-wide security program 実装
- 編集可能パス: docs/portal/issues/issue-60-gcp-preview-security-hardening-implementation.md
- 制限パス: closed issue records except explicit evidence references

受け入れ条件
- [x] 条件 1: security hardening 実装対象と baseline との差分が文書から一意に読める
- [x] 条件 2: Cloud Armor、credential / secret、audit evidence の責務分離が整理されている
- [x] 条件 3: full IAM redesign や production security program を混ぜず、preview hardening に限定できている

実装計画
- 変更見込みファイル: docs/portal/issues/issue-60-gcp-preview-security-hardening-implementation.md
- アプローチ: Issue 54 の baseline、Issue 52 / 53 の live state、Issue 57 の continuation 判断を入力に、preview long-lived operation を前提に必要な hardening を control / credential / evidence の 3 観点で整理する
- 採用しなかった代替案と理由: baseline をそのまま長期運用扱いする案は hardening gap を隠すため採らない。逆に production security roadmap を同時に作る案は preview scope を超えるため採らない

検証計画
- 実行するテスト: markdown review; get_errors on edited files
- 確認するログ/メトリクス: hardening scope wording、credential boundary wording、evidence wording の整合

```
- 失敗時の切り分け経路: docs/portal/issues/issue-54-gcp-security-baseline.md、
docs/portal/issues/issue-52-gcp-preview-workflow-execution.md、docs/portal/issues/issue-53-gcp-
preview-delivery-resource-execution.md、docs/portal/issues/issue-57-gcp-preview-continuation-
shutdown-judgment.md を照合し、baseline / hardening / retention のどこが欠けているかを分ける

リスクとロールバック
- 主なリスク: security hardening issue の名目で IAM 全面再設計や production security tooling 導入まで
scope が膨らむこと
- 影響範囲: GCP preview security posture、owner burden、cost
- 緩和策: preview hardening に限定し、full IAM redesign や organization-wide tooling は follow-up に
残す
- ロールバック手順: scope が広がりすぎた場合は Cloud Armor、credential scope、audit evidence だけを残し、
大型 security program は別 issue に切り出す
```

作業項目

- [x] hardening scope と baseline 差分を整理する
- [x] Cloud Armor / credential / secret governance を整理する
- [x] audit evidence と verification plan を整理する
- [x] preview scope 外の security 要求を切り出す

完了条件

- [x] hardening scope、owner、evidence が 1 文書で追える
- [x] baseline と hardening の境界が明示されている
- [x] preview scope 外の security program が非対象として整理されている

Initial Notes

- Issue 54 は minimum security baseline を fixed した issue である
- Issue 52 / 53 は preview path の live evidence と environment / secret 前提を残している
- preview を一定期間残すなら、minimum baseline のままではなく hardening step を分離して判断する必要がある

Issue 60 Discussion Draft

1. 今回の論点をどこまでに限定するか

提案:

- この issue は `Issue 54 の baseline から、継続運用に必要な preview hardening をどこまで実施するか` に限定する
- organization-wide security program は扱わない
- application auth 導入は扱わない

2. hardening scope の第一案

提案:

- Cloud Armor の minimum posture から tuning 可能項目を切り出す

- GitHub environment secret / variable の owner、rotation、retention を確認する
- audit evidence は workflow / resource execution / cloud audit path のつながりを再確認する

3. verification plan の第一案

提案:

- hardening 後に preview public URL、deploy path、resource path の fail-closed 条件が崩れていないことを確認する
- secret exposure や owner 不明 path を残さないことを確認する

4. Open Questions

Resolution を書く段階では、この表の `Resolution 確定文言` 列を埋めてから使うこと。

論点	判断方向（Discussion 時点の仮）	Resolution 確定文言
hardening の主対象を何に置くか	response header 強化、credential governance、audit evidence を第一候補にする	`preview security hardening の主対象は browser-facing response header 強化、gcp-preview environment credential governance、audit evidence path の固定に置く`
baseline と hardening をどう分けるか	minimum baseline を維持しつつ retained preview 向け差分だけを扱う	`Issue 54 の minimum security baseline は維持しつつ、retained preview 向け hardening 差分だけをこの issue で追加する`
Cloud Armor をどう扱うか	policy 存在は維持し、深い rule tuning は別 issue に残す	`Cloud Armor は reviewed policy attachment を維持しつつ、deep rule tuning は separate follow-up に残す`
credential / secret governance をどう扱うか	gcp-preview environment に閉じ込め、repository-wide plaintext を増やさない	`preview credential / secret governance は gcp-preview environment scope に閉じ込め、repository-wide plaintext を増やさない`
full IAM redesign を含めるか	no。別 issue に切り出す	`full IAM redesign、organization-wide security tooling、production security program は本 issue に含めない`

Resolution

Issue 60 の判断結果は次の通りとする。

- preview security hardening の主対象は browser-facing response header 強化、`gcp-preview` environment credential governance、audit evidence path の固定に置く

- Issue 54 の minimum security baseline は維持しつつ、retained preview 向け hardening 差分だけをこの issue で追加する
- Cloud Armor は reviewed policy attachment を維持しつつ、deep rule tuning は separate follow-up に残す
- preview credential / secret governance は `gcp-preview` environment scope に閉じ込め、repository-wide plaintext を増やさない
- full IAM redesign、organization-wide security tooling、production security program は本 issue に含めない

この合意で明確になること:

- retained preview は minimum baseline のままではなく、不要な browser capability をさらに絞った response header hardening を持つ
- credential surface は GitHub environment に閉じ込める運用を README と workflow documentation の両方で固定できる
- audit evidence は deploy run、deployment record、resource execution reference、monitoring state を同一 review path に残す前提が明文化される
- Cloud Armor は存在確認済みの reviewed policy を維持しつつ、risk の高い deep tuning をこの issue から切り離せる
- preview hardening と production-grade security program が明確に分離される

後続 issue への引き継ぎ事項:

- deep Cloud Armor tuning や IAM redesign が必要なら separate follow-up issue として比較・実装する
- preview shutdown が必要になった場合は credential cleanup を separate execution issue として扱う
- production-equivalent promotion judgment では retained preview hardening を前提にしつつ、別 uplift を要求する

プロセスレビュー記録

- Section 4 の open questions は `Resolution 確定文言` 列を埋めたうえで本 Resolution に統合した
- `infra/modules/portal-gcp-static-delivery/main.tf` に browser-facing header hardening を追加し、`infra/environments/gcp-preview/README.md` と `.github/workflows/README.md` に credential / audit governance を追記した
- follow-up cleanup として local apply 生成物 `infra/environments/gcp-preview/tfplan.security-hardening` は repo 管理対象に含めず、`.gitignore` に tfplan pattern を追加して再発を防ぐ
- GitHub Issue #60 の body は local issue record の最新版へ再同期する前提で扱う

現在の状態

- ISSUE CLOSED
- GitHub Issue: #60
- GitHub URL: https://github.com/PLAYER1-r7/MultiCloudProject/issues/60
- Sync Status: closed after re-review PASS
- Close Status: closed — re-review confirmed Permissions-Policy / X-Permitted-Cross-Domain-Policies headers, Cloud Armor attachment, credential governance scoping, and repo hygiene (tfplan artifact removed, .gitignore updated) complete; no blockers
- local issue record として security hardening implementation を固定した
- `infra/modules/portal-gcp-static-delivery/main.tf` に retained preview 向け response header hardening を追加した

- `infra/environments/gcp-preview/README.md` と `.github/workflows/README.md` に credential governance と audit evidence path を追記した
- `/tmp/opentofu-1.11.0/tofu apply` により gcp-preview backend bucket の response headers を live 更新し、`Permissions-Policy` と `X-Permitted-Cross-Domain-Policies` を追加した
- follow-up repo hygiene として generated tfplan artifact は削除し、tfplan pattern を ignore 対象へ追加した

依存関係

- Issue 52
- Issue 53
- Issue 54
- Issue 57